

CONSEGNA W24D4 – REPORT M6 PROGETTO SPLUNK

Progetto

Importate su Splunk i dati di esempio "tutorialdata.zip":

- Crea una query Splunk per identificare tutti i tentativi di accesso falliti "Failed password". La query dovrebbe mostrare il timestamp, l'indirizzo IP di origine, il nome utente e il motivo del fallimento.
- Scrivi una query Splunk per trovare tutte le sessioni SSH aperte con successo. La query dovrebbe filtrare per l'utente "djohnson" e mostrare il timestamp e l'ID utente.
- Scrivi una query Splunk per trovare tutti i tentativi di accesso falliti provenienti dall'indirizzo IP "86.212.199.60". La query dovrebbe mostrare il timestamp, il nome utente e il numero di porta.
- Crea una query Splunk per identificare gli indirizzi IP che hanno tentato di accedere ("Failed password") al sistema più di 5 volte. La query dovrebbe mostrare l'indirizzo IP e il numero di tentativi.
- Crea una query Splunk per trovare tutti gli Internal Server Error.

Trarre delle conclusioni sui log analizzati utilizzando AI.

Questo report presenta l'analisi completa dei log contenuti nel dataset tutorialdata.zip, importato e processato tramite Splunk. L'obiettivo del lavoro è stato quello di identificare tentativi di accesso falliti e riusciti, individuare eventuali pattern di attacco, analizzare il comportamento degli indirizzi IP coinvolti e verificare la presenza di errori applicativi interni.

L'attività è stata suddivisa in cinque esercizi principali:

Esercizio 1: identificazione dei tentativi di accesso SSH falliti, con estrazione di timestamp, IP sorgente, utente e porta.

Esercizio 2: analisi degli accessi SSH riusciti dell'utente djohnson.

Esercizio 3: analisi dei tentativi falliti provenienti da un IP specifico.

Esercizio 4: identificazione degli IP che hanno superato la soglia di 5 tentativi falliti.

Esercizio 5: individuazione degli errori applicativi (HTTP 500) e analisi delle URI coinvolte.

Dai risultati emerge un quadro chiaro:

Il sistema è stato oggetto di numerosi tentativi di brute force SSH, provenienti da IP differenti, alcuni dei quali estremamente aggressivi.

L'utente legittimo djohnson accede sempre da un unico IP stabile, senza correlazioni con gli attacchi.

Gli errori applicativi HTTP 500 sono numerosi e indicano malfunzionamenti del backend, non correlati agli attacchi SSH.

INTRODUZIONE A SPLUNK

Splunk è una piattaforma software progettata per raccogliere, indicizzare e analizzare grandi quantità di dati generati da sistemi informatici, applicazioni, dispositivi di rete e infrastrutture IT. La sua forza principale risiede nella capacità di trasformare log grezzi, spesso complessi e difficili da interpretare, in informazioni strutturate, visualizzabili e facilmente analizzabili. Questo permette di ottenere una visione immediata e approfondita del comportamento di un sistema, facilitando attività come il monitoraggio, la diagnostica, la sicurezza e l'ottimizzazione delle prestazioni.

Splunk viene utilizzato in contesti molto diversi: dalla cybersecurity al monitoraggio applicativo, dalla gestione dei sistemi alla business intelligence. In ambito di sicurezza, ad esempio, consente di individuare

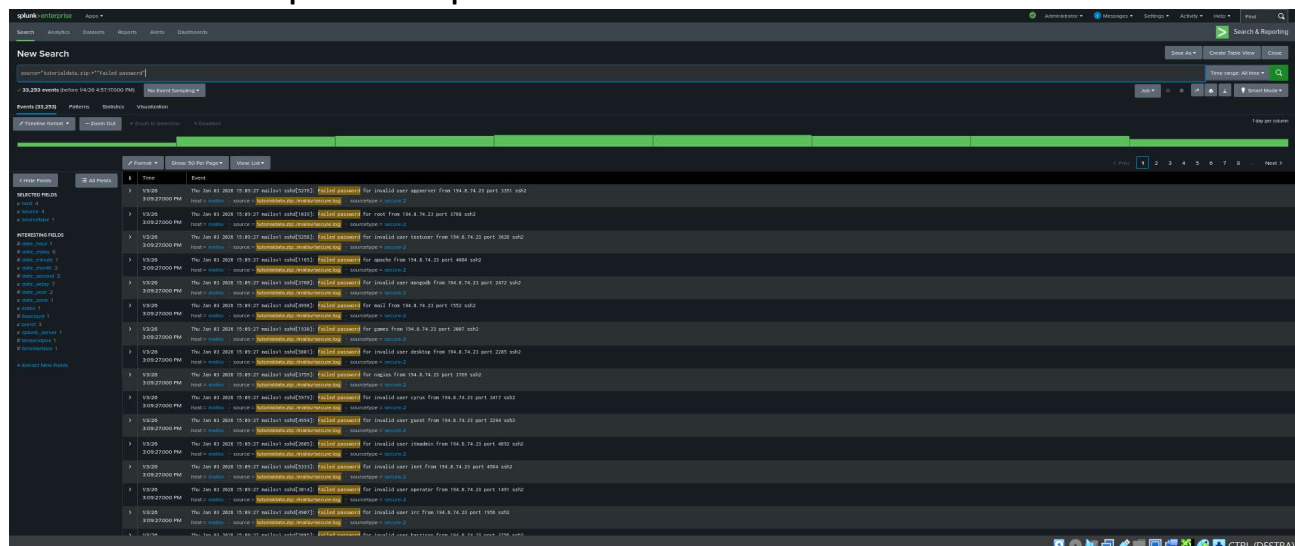
tentativi di accesso sospetti, analizzare pattern di attacco, correlare eventi provenienti da fonti differenti e supportare attività di incident response. In ambito applicativo, invece, permette di identificare errori, rallentamenti, anomalie e problemi di backend, fornendo strumenti utili per migliorare la stabilità e l'affidabilità dei servizi.

Uno degli aspetti più apprezzati di Splunk è la sua capacità di correlare eventi diversi e di fornire una visione unificata del sistema. Questo lo rende uno strumento essenziale per analizzare comportamenti complessi, individuare anomalie e prendere decisioni basate su dati reali.

ESERCIZIO 1 - TENTATIVI DI ACCESSO FALLITI

L'obiettivo del primo esercizio è identificare tutti i tentativi di accesso falliti presenti nei log, estraendo informazioni utili come timestamp, indirizzo IP sorgente, nome utente e porta utilizzata. La ricerca parte filtrando gli eventi che contengono la stringa "Failed password", tipica dei log SSH quando un'autenticazione non va a buon fine. Attraverso il comando rex, la query estrae in modo strutturato i campi user, src_ip e port direttamente dal testo grezzo dei log. Questo permette di trasformare informazioni non strutturate in campi analizzabili, facilitando la lettura e l'interpretazione dei dati.

source="tutorialdata.zip:*" "Failed password"

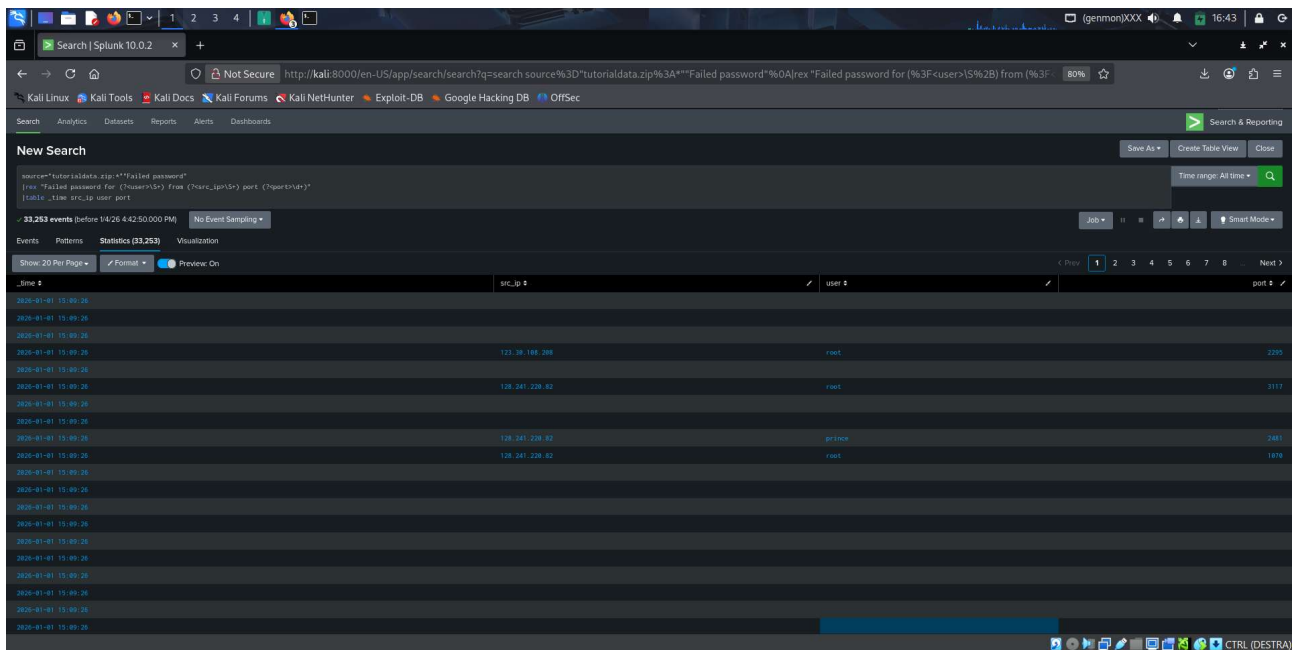


andiamo poi ad estrarre campi di testo con la funzione "rex" e aggiungiamo una seconda funzione "table"

source=tutorialdata:* "Failed password"

| rex "Failed password for (?<user>\S+) from (?<src_ip>\S+) port (?<port>\d+)"

| table _time src_ip user port

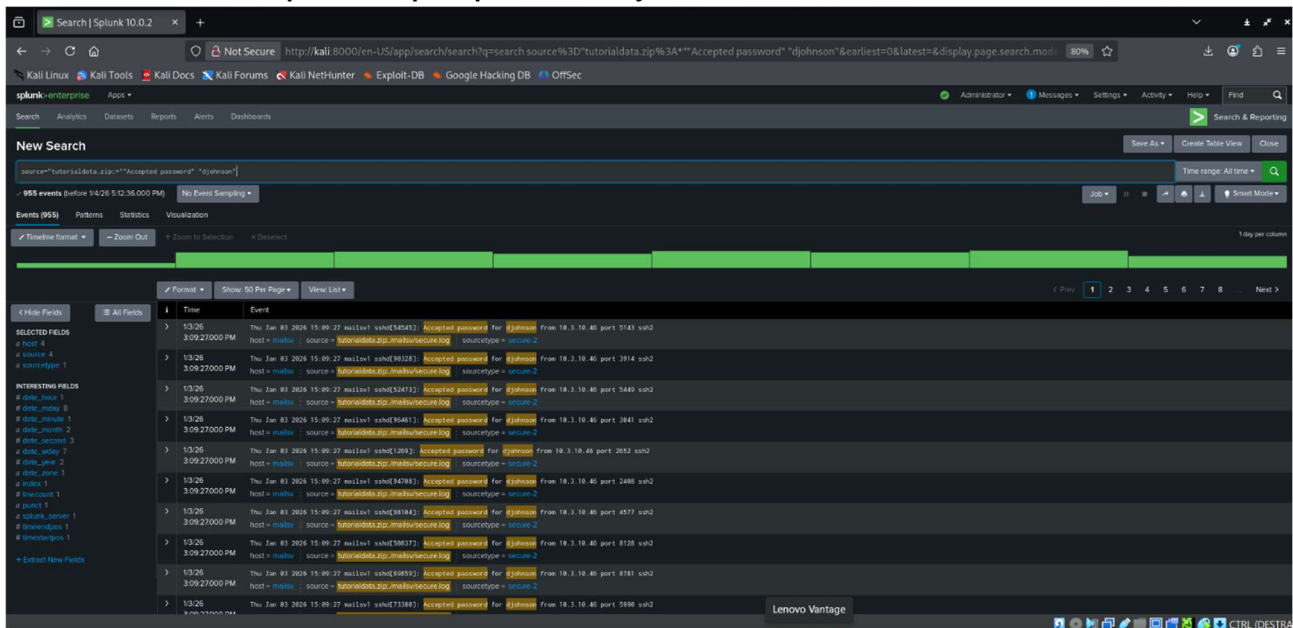


ESERCIZIO 2 - SESSIONI SSH APERTE CON SUCCESSO PER DJOHNSON

Il secondo esercizio richiede di individuare tutte le sessioni SSH aperte con successo dall'utente "djohnson". La ricerca filtra gli eventi che contengono la stringa "Accepted password", indicativa di un'autenticazione avvenuta correttamente. Attraverso il comando rex, vengono estratti i campi user e src_ip, che permettono di identificare rispettivamente l'utente autenticato e l'indirizzo IP da cui è avvenuto l'accesso.

Successivamente, la query filtra i risultati mantenendo solo quelli relativi all'utente "djohnson", come richiesto dall'esercizio. La tabella finale mostra il timestamp dell'accesso, l'utente e l'indirizzo IP sorgente. Generalmente gli accessi riusciti compaiono sotto la voce "Accepted password" quindi andiamo a cercare nella barra di ricerca

source="tutorialdata.zip:*" "Accepted password" "djohnson"



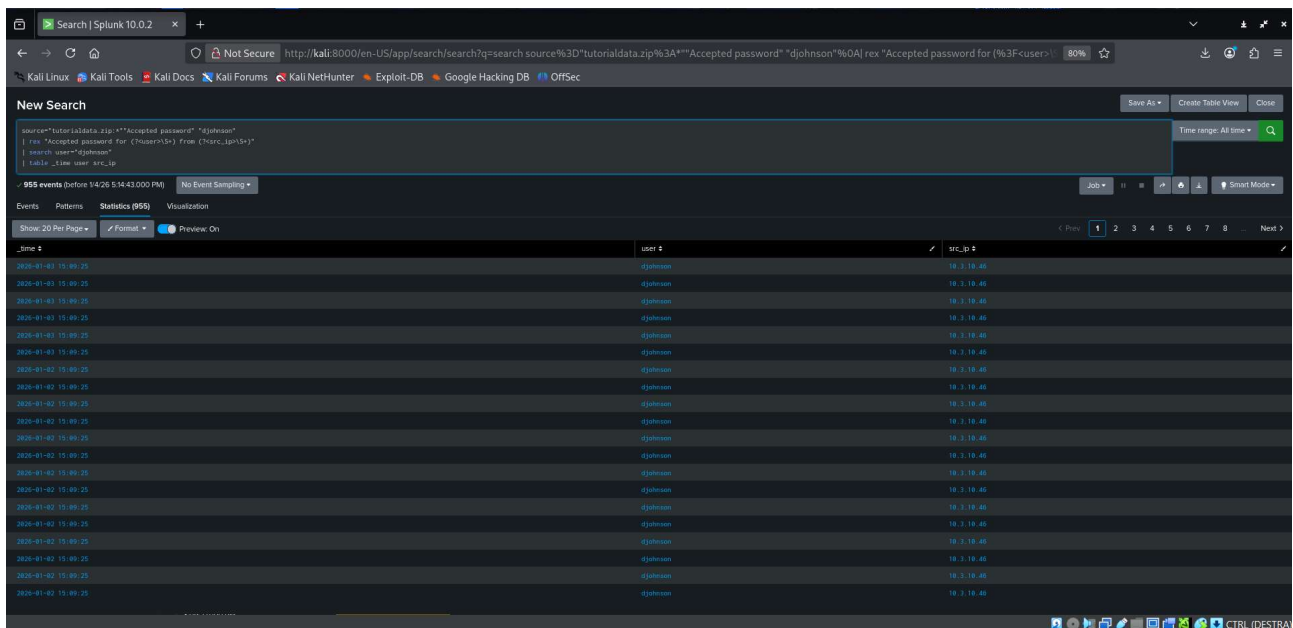
per esaudire la richiesta della traccia completiamo la query

source="tutorialdata.zip:*" "Accepted password"

| rex "Accepted password for (?<user>\\$+) from (?<src_ip>\\$+)"

| search user="djohnson"

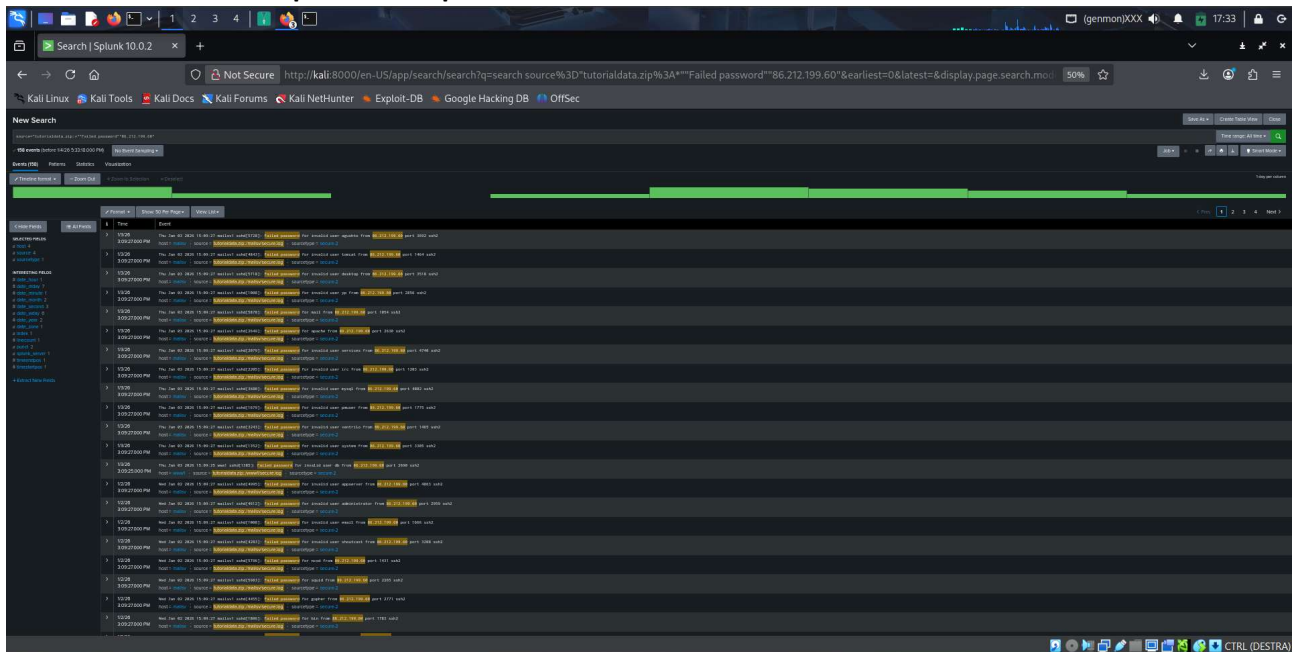
| table _time user src_ip



ESERCIZIO 3 - TENTATIVI DI ACCESSO FALLITI DALL'IP 86.212.199.60

Il terzo esercizio si concentra sull'analisi dei tentativi di accesso falliti provenienti da un indirizzo IP specifico: 86.212.199.60. La query filtra gli eventi che contengono sia la stringa "Failed password" sia l'indirizzo IP indicato, isolando così solo i tentativi provenienti da quella sorgente. Attraverso il comando rex, vengono estratti i campi user e port, che permettono di identificare l'utente bersaglio e la porta utilizzata durante il tentativo di accesso. La visualizzazione tabellare finale mostra il timestamp, l'utente e la porta, consentendo di ricostruire la sequenza temporale dei tentativi falliti provenienti da quell'IP.

source= "tutorialdata.zip:*" "Failed password" "86.212.199.60"

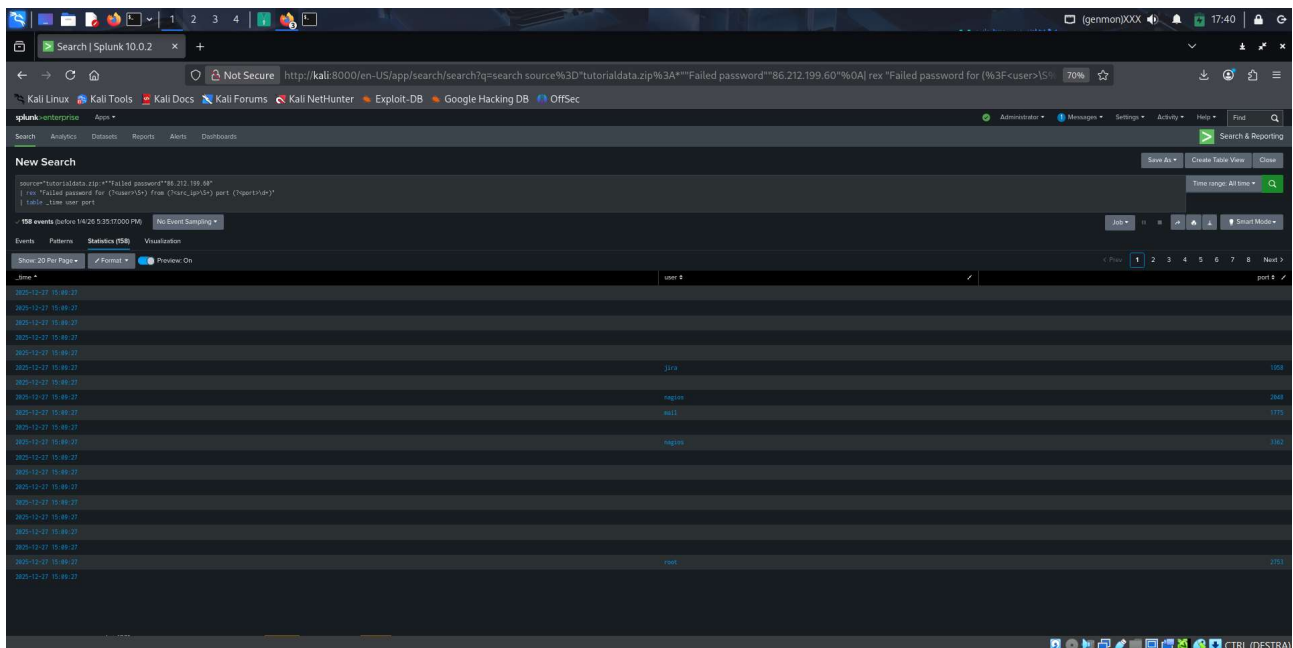


Successivamente andiamo poi ad estrarre username, ip e porta tramite la funzione rex e andiamo a creare una tabella che ci mostra i dati da noi richiesti in maniera leggibile e chiara

source= "tutorialdata.zip:*" "Failed password" "86.212.199.60"

| rex "Failed password for (?<user>\S+) from (?<src_ip>\S+) port (?<port>\d+)"

| table _time user port



ESERCIZIO 4 - IP CHE HANNO TENTATO ACCESSO FALLITO PIU' DI 5 VOLTE

La query analizza gli eventi contenenti la stringa “Failed password” e utilizza il comando rex per estrarre in modo strutturato l’indirizzo IP sorgente da ciascun log.

Successivamente, tramite il comando “stats count by src_ip”, gli eventi vengono aggregati per indirizzo IP, ottenendo il numero totale di tentativi falliti per ciascuna sorgente. Il filtro where count > 5 permette di isolare solo gli IP che superano la soglia di cinque tentativi, evidenziando potenziali attività sospette come attacchi di brute force o scansioni automatizzate.

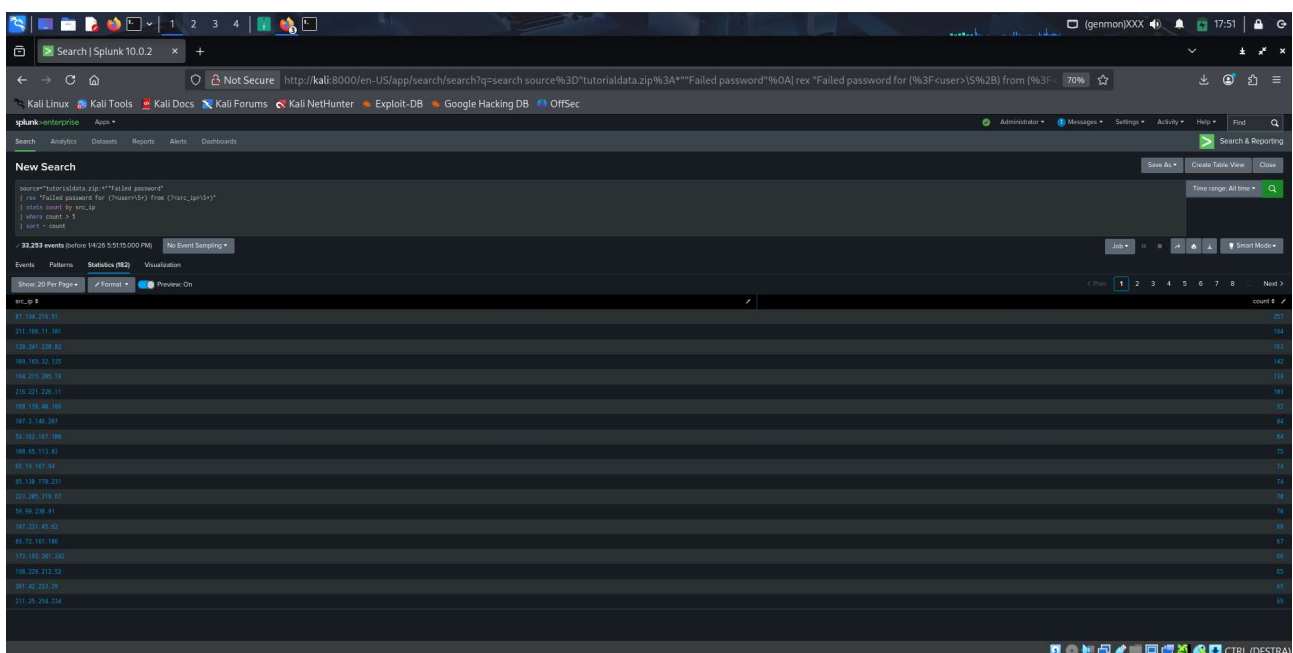
source=“tutorialdata.zip:*” “Failed password”

| rex “Failed password for (?<S+>) from (?<S+>)”

| stats count by src_ip

| where count > 5

| sort - count



ESERCIZIO 5 - IDENTIFICAZIONE DEGLI INTERNAL SERVER ERROR

Per il quinto esercizio è stata eseguita una ricerca mirata a individuare tutti gli errori applicativi presenti nel dataset tutorialdata.zip. Sebbene nei log non compaia la stringa testuale “Internal Server Error”, l’analisi ha evidenziato che il dataset contiene log HTTP, nei quali gli errori interni del server sono rappresentati dal codice di stato 500. La query utilizzata filtra gli eventi provenienti dal file di origine e seleziona esclusivamente quelli con status=500, corrispondenti a errori interni del server. Successivamente, i risultati vengono presentati in forma tabellare, mostrando il timestamp dell’evento, l’indirizzo IP sorgente, l’URI richiesto e il codice di stato. L’analisi ha restituito numerosi eventi con codice 500, indicando che l’applicazione web simulata ha generato diversi errori. Questo tipo di informazione è fondamentale per individuare malfunzionamenti applicativi o comportamenti anomali che possono compromettere l’esperienza utente o la stabilità del servizio.

```
source="tutorialdata.zip" status=500
```

```
| table _time src_ip uri status
```

Search | Splunk 10.0.2

Not Secure | https://kali:8000/en-US/app/search/search?q=search source%3Dtutorialdata.zip%3A** status%3D500%0A table _time src_ip uri status&earliest=0&latest=&display=page

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Administrator Messages Settings Activity Help Find Search & Reporting

New Search

733 events Before 14/05 04:12:00 PM No Event Sampling

Events Patterns Statistics (733) Visualization

Show: 20 Per Page # Format View Preview On

_time	src_ip	uri	Status
2025-12-27 19:16:11	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:12	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:13	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:14	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:15	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:16	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:17	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:18	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:19	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:20	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:21	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:22	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:23	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:24	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:25	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:26	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:27	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:28	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:29	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:30	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:31	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:32	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:33	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:34	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:35	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:36	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:37	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:38	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:39	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:40	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:41	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:42	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:43	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:44	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:45	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:46	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:47	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:48	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:49	192.168.1.1	/api/v1/auth/login	200
2025-12-27 19:16:50	192.168.1.1	/api/v1/auth/login	200

CONCLUSIONI TRATTE ANALIZZANDO I RISULTATI DEI TEST

1. Confronto tra risultati esercizio 1 e esercizio 4 (Tentativi falliti singoli con IP più aggressivi)

Dai risultati notiamo che ci sono IP che compaiono tante volte e analizzando i risultati dell'esercizio 4 notiamo che tra gli IP più aggressivi ci sono:

87.194.216.51 con 257 tentativi

211.164.11.101 con 194 tentativi

128.241.220.82 con 132 tentativi

Questi stessi IP compaiono anche nell'esercizio 1, ma in quell'occasione vediamo evento per evento. Inoltre notiamo come molti tentativi falliti avvengono tutti nello stesso secondo o comunque in intervalli temporali molto ravvicinati questo ci indica un comportamento di tentativi di accesso non umano di conseguenza automatizzato dove gli IP più aggressivi generano tentativi continui spesso con username diversi

Questi risultati sono un chiaro segnale di brute force automatizzato.

2. Confronto risultati dell'esercizio 1–3 con quelli dell'esercizio 2 (Tentativi falliti vs. accessi riusciti dell'utente "djohnson")

Confrontando questi risultati andiamo a vedere se ci sono utenti che falliscono molteplici accessi per poi avere un accesso riuscito. Dai quello che evince è che gli utenti che falliscono non compaiono mai negli

accessi riusciti e che l'unico utente con accessi riusciti è djohnson che non compare mai tra gli utenti falliti. Questo risultato riduce il rischio di compromissione dell'account. Lo stesso risultato che otteniamo confrontando gli indirizzi ip che compaiono nei tentativi falliti e in quelli riusciti.

Questi risultati dimostrano che il sistema è riuscito a resistere ai tentativi di intrusione.

3. Confronto con Query 5 (Errori HTTP 500) (Errori applicativi vs. tentativi SSH)

Confrontando i tentativi SSH notiamo che sono eventi concentrati in intervalli temporali diversi da quelli in cui si presentano errori HTTP 500 dimostrando che **non ci sono correlazioni tra i picchi di attacco di bruteforce e picchi di errori applicativi.**

Conclusioni finali

L'analisi è stata condotta sui log contenuti nel dataset tutorialdata.zip, importato in Splunk e suddiviso in due principali categorie di eventi:

Log SSH: tentativi di accesso riusciti e falliti al sistema.

Log HTTP: richieste web con codici di stato, incluse anomalie applicative (HTTP 500).

L'obiettivo era identificare pattern di sicurezza, comportamenti sospetti e possibili malfunzionamenti applicativi.

La lettura complessiva dei log analizzati attraverso Splunk permette di ricostruire un quadro chiaro e articolato dello stato del sistema e delle dinamiche che lo hanno interessato. L'insieme dei dati raccolti evidenzia innanzitutto una costante attività ostile sul fronte SSH: numerosi indirizzi IP, alcuni dei quali particolarmente aggressivi, hanno generato un volume significativo di tentativi di accesso falliti. La rapidità con cui questi tentativi si susseguono, spesso concentrati nello stesso secondo e accompagnati da username generici o comunemente presi di mira, indica con buona certezza l'impiego di strumenti automatizzati di brute force. Nonostante ciò, l'analisi non mostra alcun segnale di compromissione: gli IP responsabili dei tentativi falliti non compaiono mai tra gli accessi riusciti e nessuno degli utenti bersagliati risulta aver ottenuto un login valido. L'unico utente che accede correttamente al sistema, *djohnson*, lo fa sempre dalla stessa sorgente, un indirizzo IP stabile e coerente con un comportamento legittimo. Questo elemento rafforza l'idea che, pur essendo sotto pressione, il sistema abbia mantenuto la propria integrità.

Parallelamente, l'analisi dei log HTTP rivela un secondo fenomeno, completamente distinto dal primo: un numero elevato di errori 500, distribuiti in un intervallo temporale definito e legati a operazioni tipiche di un'applicazione web, come la gestione del carrello, la visualizzazione dei prodotti o la navigazione tra categorie. Questi errori non mostrano alcuna correlazione temporale con i tentativi di brute force e non sembrano essere il risultato di un attacco esterno. Al contrario, suggeriscono la presenza di problemi interni all'applicazione, probabilmente legati a malfunzionamenti del backend, eccezioni non gestite o configurazioni errate. La natura ripetitiva e concentrata degli errori indica che l'applicazione non è in grado di gestire correttamente alcune richieste, compromettendo la stabilità del servizio.

Nel complesso, l'analisi mette in luce due criticità differenti: da un lato la necessità di rafforzare la sicurezza del servizio SSH, implementando misure di hardening come l'autenticazione a chiave pubblica, sistemi di blocco automatico e restrizioni sugli indirizzi IP autorizzati; dall'altro, l'urgenza di intervenire sull'applicazione web per individuare e correggere le cause degli errori 500, migliorando la gestione delle eccezioni e la stabilità del backend. Splunk si è rivelato uno strumento essenziale per distinguere questi due fenomeni, permettendo di analizzare in modo strutturato eventi e di ricostruire un quadro preciso delle condizioni operative del sistema. L'insieme delle evidenze raccolte suggerisce che, pur non essendo stato compromesso, il sistema necessita di interventi mirati sia sul fronte della sicurezza sia su quello applicativo, al fine di garantire un ambiente più robusto, affidabile e resiliente.